

The 5-Minute Repo Security Checklist

A quick manual pass before you push — from CipherCapital

1. Secrets

- Search your repo for common secret patterns: **grep -rEn "(api[_-]?key|secret|password|token)\s*="** .
- Check your git history too — a deleted secret in commit history is still exposed: **git log -p | grep -i "api_key"**
- Confirm **.env** and any credential files are listed in **.gitignore** — and were *always* ignored, not added after the fact.

2. Dependencies

- Check for known vulnerabilities in your packages: **npm audit** or **pip-audit**, depending on your stack.
- Look for dependencies that haven't been updated in over a year — abandoned packages are a common entry point.
- Pin versions in production — avoid open-ended ranges like **^** or ***** for anything security-sensitive.

3. Infrastructure as Code

- Dockerfiles: confirm you're not running as **root** — add a **USER** instruction.
- Check for hardcoded IPs, ports, or credentials in Terraform / Kubernetes manifests.
- Confirm cloud storage buckets (S3, GCS) default to private, not public-read.

4. Quick wins

- Enable 2FA on GitHub, GitLab, and any CI/CD platform you use — ideally with a hardware key, not SMS.
- Turn on Dependabot (or equivalent) so dependency alerts reach you automatically, not just at review time.
- Add a **SECURITY.md** file to your repo so contributors know how to report issues responsibly.

Want this running automatically on every commit, across your whole repo, instead of checking manually? That's exactly what SecurityAuditAI does — full scan in under 2 minutes, free to try. **[ciphercapital hub page](#) → Free Security Audit.**

CipherCapital — cybersecurity tutorials that ship fixes, not theory.